

Why Code Security Matters - Even in Hardened Environments

Why Code Security Matters - Even in Hardened Environments - Stefan Schiller, Sonar.

- Published: 2024-10-08
- Original: <<https://www.sonarsource.com/blog/why-code-security-matters-even-in-hardened-environments/>>
- Preserved from: <https://www.sonarsource.com/blog/why-code-security-matters-even-in-hardened-environments/> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

TL;DR overview

- Code security matters in hardened environments because network-level defenses like firewalls, WAFs, and network segmentation do not eliminate vulnerabilities in the application code itself.
- Defense in depth requires securing every layer, including the code: a single application-level vulnerability can provide an attacker with a foothold that bypasses all perimeter protections.
- Hardened environments often create a false sense of security that leads to reduced attention to code-level vulnerabilities, making the eventual exploitation more damaging.
- Integrating SAST into the development pipeline ensures that code security is enforced regardless of the deployment environment's infrastructure protections.

Infrastructure hardening makes applications more resilient to attacks. These measures raise the bar for attackers, making exploitation more difficult. However, they should not be seen as a silver bullet, as determined attackers can still leverage vulnerabilities in the source code.

In this blog post, we will highlight the importance of fundamental code security by showcasing a technique that attackers can use to turn a file write vulnerability in a Node.js application into remote code execution – even though the target's file system is mounted read-only. The technique thwarts the restrictions applied in a hardened environment like this by leveraging exposed pipe file descriptors to gain code execution.

This blog post's content was also presented at [Hexacon24](#). We will add a link to the recording as soon as it is available and let you know on [X/Twitter](#) and [Mastodon](#).

File Write Vulnerabilities

During our mainly web-focused vulnerability research, we encounter a variety of different vulnerability types, such as Cross-Site Scripting, SQL injection, Insecure Deserialization, Server-Side Request Forgery, and much more. The impact and ease of exploitation of these vulnerability types varies but for a few of them, it is almost certain to assume that the whole application is comprised once that type of vulnerability is identified.

One of these critical vulnerability types is an **Arbitrary File Write** vulnerability. Attackers still need to figure out what to write where, but there are usually a lot of options to turn this into code execution and thus fully compromise the application's server:

- Write a PHP, JSP, ASPX, or similar file to the web root.
- Overwrite a templating file that is processed by a server-side templating engine.
- Write to a configuration file (e.g., [uWSG .ini file](#) or [Jetty .xml file](#)).
- Add a Python [site-specific configuration hook](#).
- Use a generic approach by writing an SSH key, adding a cronjob, or overwriting a user's .bashrc file.

These examples show that attackers usually find an easy way to turn an Arbitrary File Write vulnerability into code execution. To reduce the extent of such vulnerabilities, an application's underlying infrastructure is often hardened – making it more difficult but not impossible for attackers to exploit it.

File Writes in Hardened Environments

We recently encountered an Arbitrary File Write vulnerability in a Node.js application that turned out to be less easily exploitable. The vulnerability itself was more complex, but it breaks down to the following vulnerable code snippet:

Copy to clipboard

```
app.post('/upload', (req, res) => {  
  const { filename, content } = req.body;  
  fs.writeFile(filename, content, () => {  
    res.json({ message: 'File uploaded!' });  
  });  
});
```

The function `fs.writeFile` is used to write a file, and both parameters – `filename` and `content` – are fully user-controllable. Thus, this is an Arbitrary File Write vulnerability.

When determining the impact of this vulnerability, we noticed that the user running the application is limited to write-permissions for a specific upload folder. **Everything else on the file system is read-only.** Although this felt like a dead-end for the exploitation of the vulnerability, it led us to the following research question:

Can an Arbitrary File Write vulnerability possibly be turned into code execution even though the target's file system is mounted read-only?

Read-Only File Writes

On Unix-based systems like Linux, everything is a file. Unlike traditional file systems like ext4, which store data on a physical hard disk drive, there are other file systems that serve a different purpose. One of these is the [procfs virtual file system](#), which is usually mounted at `/proc` and acts as a window into the kernel's inner workings. Instead of storing actual files, procfs provides access to real-time information about running processes, system memory, hardware configuration, and more.

One particularly interesting piece of information procfs provides is the open file descriptors of a running process, which can be inspected via `/proc/<pid>/fd/`. The files opened by a process may not only be traditional files but also device files, sockets, and pipes. For example, the following command can be used to list the open file descriptors of the Node.js process:

Copy to clipboard

```
user@host:~$ {% mark yellow %}ls -al /proc`pidof node`/fd{% mark %}
total 0
dr-x----- 2 user user 22 Oct 8 13:37 .
dr-xr-xr-x 9 user user  0 Oct 8 13:37 ..
lrwx----- 1 user user 64 Oct 8 13:37 0 -> /dev/pts/1
lrwx----- 1 user user 64 Oct 8 13:37 1 -> /dev/pts/1
lrwx----- 1 user user 64 Oct 8 13:37 2 -> /dev/pts/1
lrwx----- 1 user user 64 Oct 8 13:37 3 -> 'anon_inode:[eventpoll]'
lr-x----- 1 user user 64 Oct 8 13:37 4 -> 'pipe:[9173261]'
l-wx----- 1 user user 64 Oct 8 13:37 5 -> 'pipe:[9173261]'
lr-x----- 1 user user 64 Oct 8 13:37 6 -> 'pipe:[9173262]'
l-wx----- 1 user user 64 Oct 8 13:37 7 -> 'pipe:[9173262]'
lrwx----- 1 user user 64 Oct 8 13:37 8 -> 'anon_inode:[eventfd]'
lrwx----- 1 user user 64 Oct 8 13:37 9 -> 'anon_inode:[eventpoll]'
...
```

As we can see from the output above, this also includes anonymous pipes (e.g., `pipe:[9173261]`). Unlike named pipes, which are exposed as a named file on the file system, writing to anonymous pipes is usually impossible due to the lack of a reference. However, the procfs filesystem allows us to reference the pipe via its entry in `/proc/<pid>/fd/`. Compared to other files under procfs, this file write does not require root privileges and can be performed by the low-privileged user running the Node.js application:

Copy to clipboard

```
user@host:~$ {% mark yellow %}echo hello > /proc`pidof node`/fd/5{% mark %}
```

Writing to a pipe is even possible if `procfs` is mounted read-only (e.g. in a Docker container) since pipes are handled by a separate filesystem called `pipefs`, which is internally used by the kernel.

This unveils new attack surfaces for attackers who can write arbitrary files as they can feed data to the event handler that reads from an anonymous pipe.

Node.js and Pipes

Node.js is built on the V8 JavaScript engine, which is single-threaded. However, Node.js provides an asynchronous and non-blocking event loop. To do so, it uses a library called `libuv`. This library uses anonymous pipes to signal and handle events, which are exposed via `procfs` as we saw in the output above.

When a Node.js application is prone to a file write vulnerability, nothing prevents attackers from writing to these pipes, as they are writable by the same user running the application. But what happens with the data written to the pipes?

When auditing the related `libuv` source code, a handler named `uv_signal_event` caught our attention. It assumes that the data read from the pipe are messages of type `uv_signal_msg_t`:

Copy to clipboard

```
static void {% mark yellow %}uv_signal_event{% mark %}(uv_loop_t* loop,
              uv_io_t* w,
              unsigned int events) {
    {% mark yellow %}uv_signal_msg_t{% mark %} msg;
    // [...]

    do {
        r = {% mark yellow %}read{% mark %}(loop->{% mark yellow %}signal_pipefd[0]{% mark %}, {% mark yellow %}buf{%
        // [...]

        for (i = 0; i < end; i += sizeof(uv_signal_msg_t)) {
            {% mark yellow %}msg = (uv_signal_msg_t*) (buf + i){% mark %}
            // [...]
```

The `uv_signal_msg_t` data structure only contains two members, a `handle` pointer and an integer called `signum`:

Copy to clipboard

```
typedef struct {
    {% mark yellow %}uv_signal_t* handle{% mark %}
    int signum;
} uv_signal_msg_t;
```

The `uv_signal_t` type of the `handle` pointer is a typedef for the `uv_signal_s` data structure, which contains a particularly interesting member called `signal_cb` :

Copy to clipboard

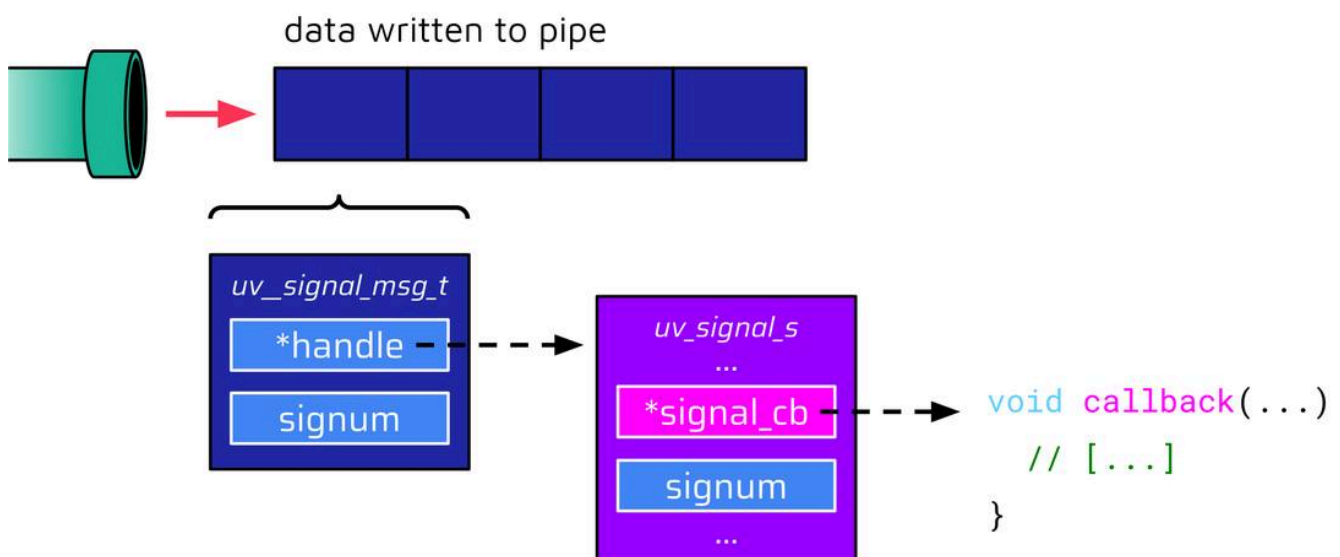
```
struct uv_signal_s {
    UV_HANDLE_FIELDS
    {% mark yellow %}uv_signal_cb signal_cb;{% mark %}
    int signum;
    // [...]
```

This `signal_cb` member is a function pointer that is supposed to contain the address of a callback function that is invoked later on in the event handler if the `signum` value of both data structures matches:

Copy to clipboard

```
// [...]\n{% mark yellow %}handle = msg->handle;{% mark %}\n\nif ({% mark yellow %}msg->signum == handle->signum{% mark %}) {\n    assert(!(handle->flags & UV_HANDLE_CLOSING));\n    {% mark yellow %}handle->signal_cb{% mark %}(handle, handle->signum);\n}\n}
```

The following image visualizes the data structure that the event handler expects:



This is a very promising situation for attackers: They can write any data to the pipe, and there is a quick path to the invocation of a function pointer. In fact, we were not the only and first researchers to notice this. On August 8, HackerOne disclosed [this great report](#) from [Seunghyun Lee](#), in which he describes a different scenario in which he was able to leverage the open file

descriptor from within a Node.js program to bypass any module- and process-based permission – basically a sandbox escape.

Even in the scenario he described here – which we didn't have in mind – this is not considered a security vulnerability, and the report was closed as informative. That means that the technique we describe in the following sections still applies to the latest version of Node.js and this will probably not change in the near future.

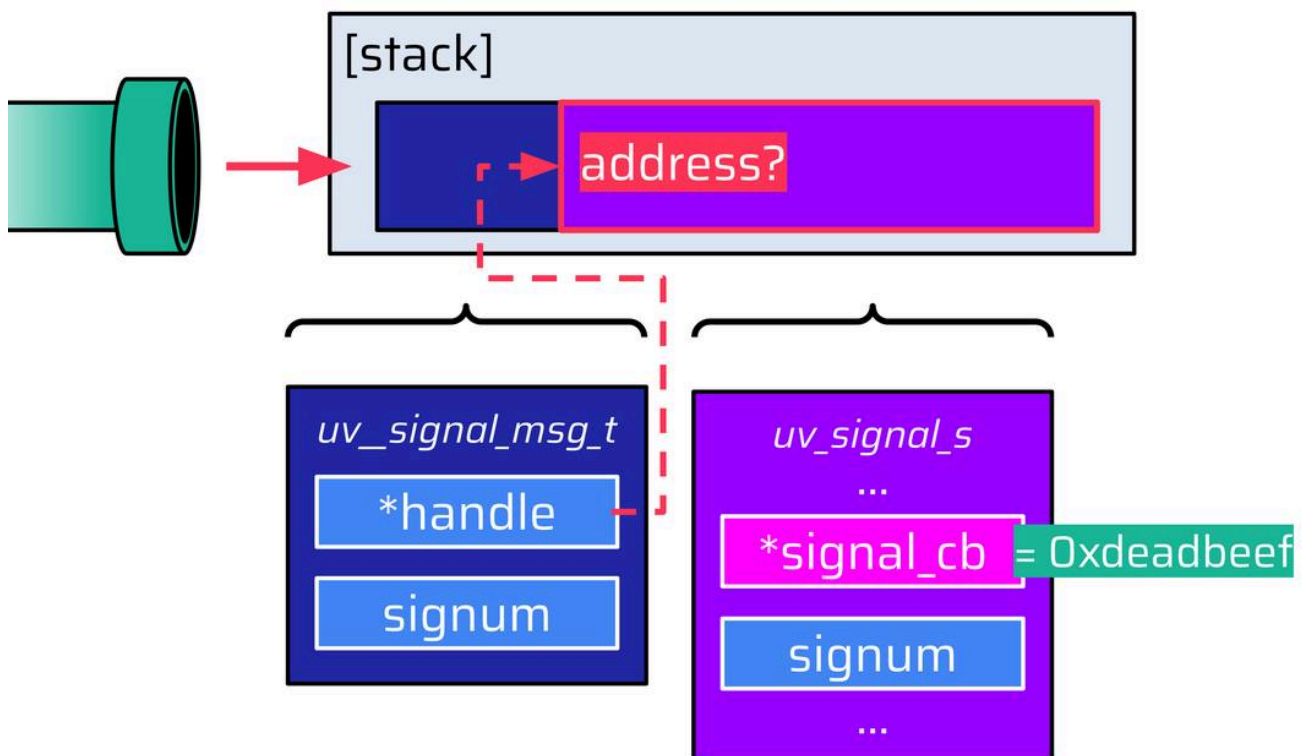
Building Structures

The general strategy of attackers exploiting the event handler with a file write vulnerability may look like this:

- Write a fake `uv_signal_s` data structure to the pipe.
- Set the `signal_cb` function pointer to an arbitrary address that they would like to call.
- Write a fake `uv_signal_msg_t` data structure to the pipe.
- Set the `handle` pointer to the `uv_signal_s` data structure written before.
- Set the `signum` value for both data structures to the same value.
- Gain arbitrary code execution.

Assuming that attackers can only write files, all of this needs to be achieved with a one-shot write without the ability to read any memory beforehand.

The buffer of the event handler is quite huge, which allows attackers to easily write both data structures to the pipe. However, there is a hurdle: the address of the data structures is unknown since all data written to the pipe is stored on the stack:



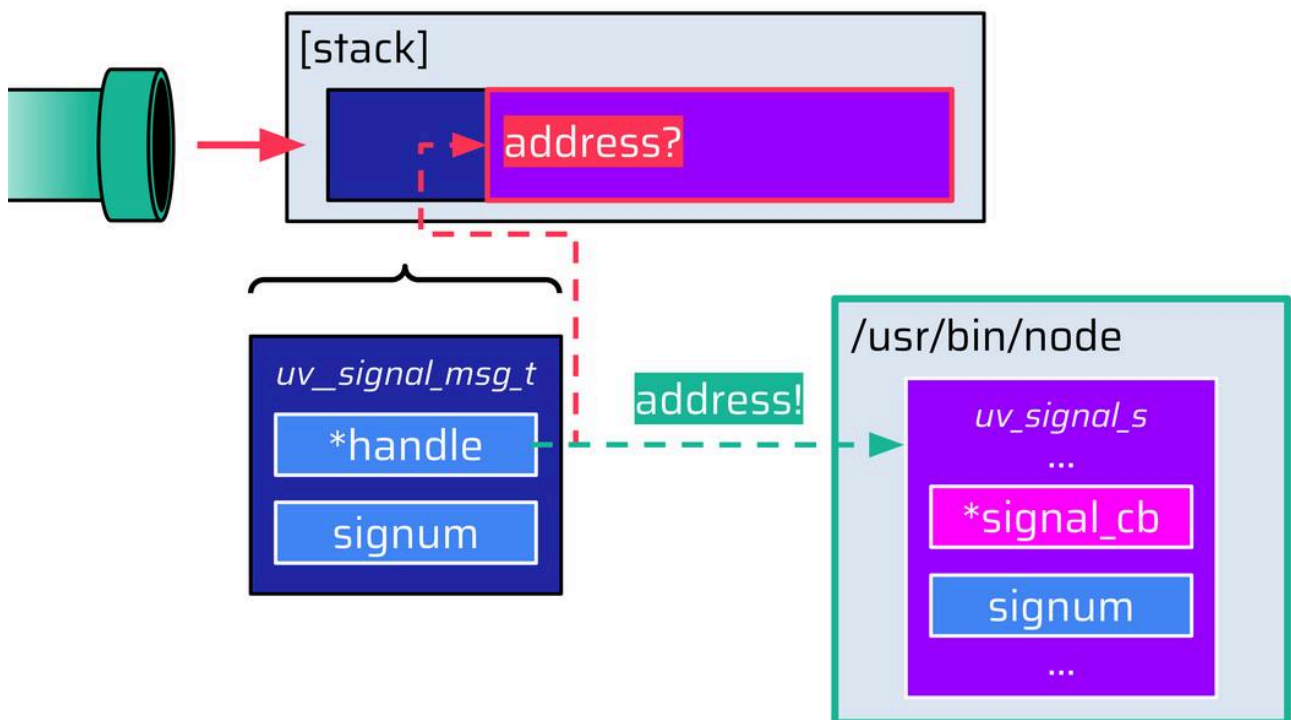
Thus, attackers wouldn't be able to make the `handle` pointer reference the fake `uv_signal_s` data structure. This leads to the question: Is there even any data that attackers could reference?

The addresses of the stack, the heap, and all libraries are randomized via ASLR. However, the segments of the Node.js binary itself are not. To our surprise, PIE (position-independent executable) is not enabled for the official Linux build of Node.js:

Copy to clipboard

```
user@host:~$ checksec /opt/node-v22.9.0-linux-x64/bin/node
[*] '/opt/node-v22.9.0-linux-x64/bin/node'
  Arch:   amd64-64-little
  RELRO:   Full RELRO
  Stack:   No canary found
  NX:      NX enabled
  {% mark yellow %}PIE:   No PIE (0x400000){% mark %}
```

The reasons for this are apparently [performance considerations](#), as the indirect addressing of PIE adds a small overhead. For attackers, this means that they could reference data in a Node.js segment since this address is known:

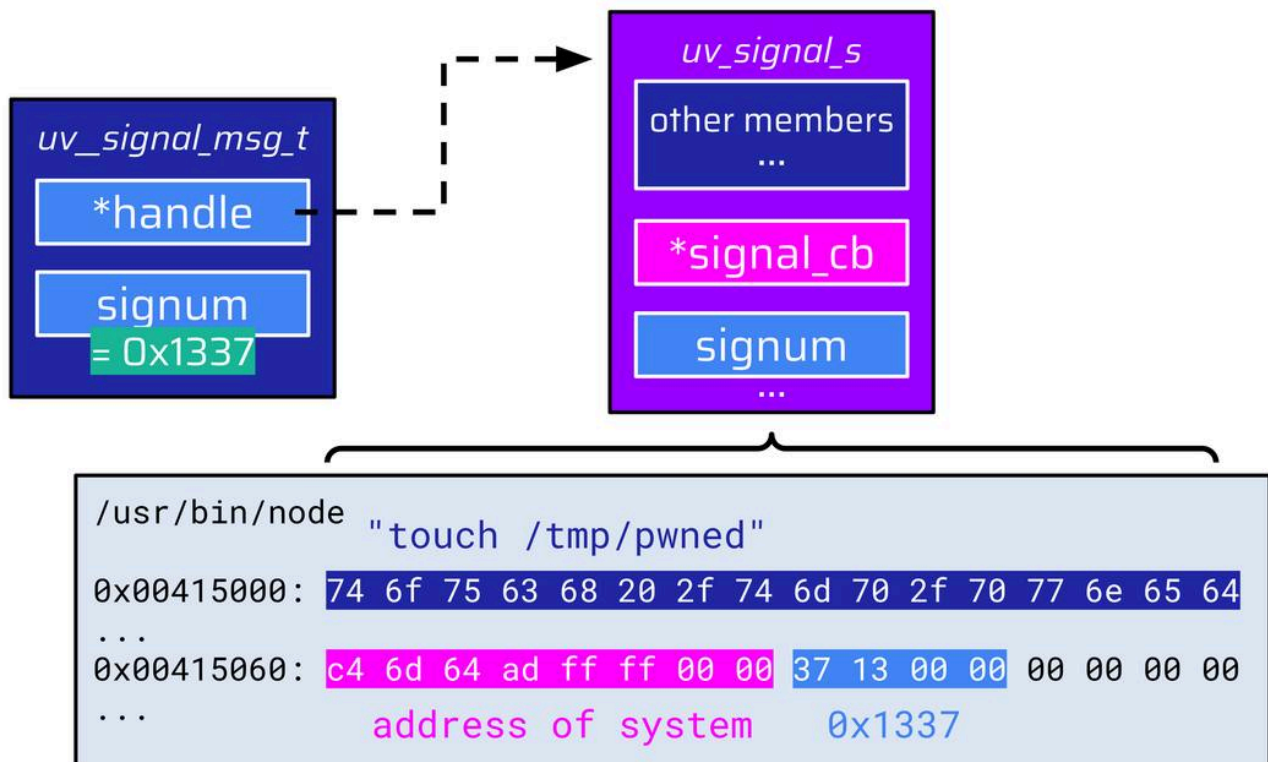


The next question is: How could attackers store a fake `uv_signal_s` data structure in a Node.js segment? Searching for ways to make Node.js store attacker-controlled data at a static location (e.g. data read from an HTTP request) would be one approach, but this seemed to be quite challenging.

An easier approach is to just use what is already available. By examining the Node.js memory segments, attackers may be able to identify suitable data for a `uv_signal_s` fake structure in the

existing data.

The attackers' dream data structure would look similar to this:



This data structure begins with a command string (`"touch /tmp/pwned"`) followed by the address of `system` at the correct offset to overlap with the `signal_cb` function pointer. Attackers would only need to make the `signum` value match the fake `uv_signal_s` data structure so that the callback function is invoked, which effectively calls `system("touch /tmp/pwned")`.

This approach requires the address of `system` to be present in a Node.js segment. The global offset table (GOT) would usually be a candidate for this. However, Node.js does not use the `system` function, so its address is not present in the GOT. And even if it were present, the beginning of the resulting fake `uv_signal_s` data structure would likely be another entry in the GOT and not a useful command string. Thus, another approach seems more viable: a classical ROP chain.

Searching Data Structure Gadgets

The beginning of every ROP chain is the search for useful ROP gadgets. A tool that searches for ROP gadgets usually parses the ELF file on disk and then determines all executable sections. The `.text` section is usually the biggest executable section since it stores the instructions of the program itself:



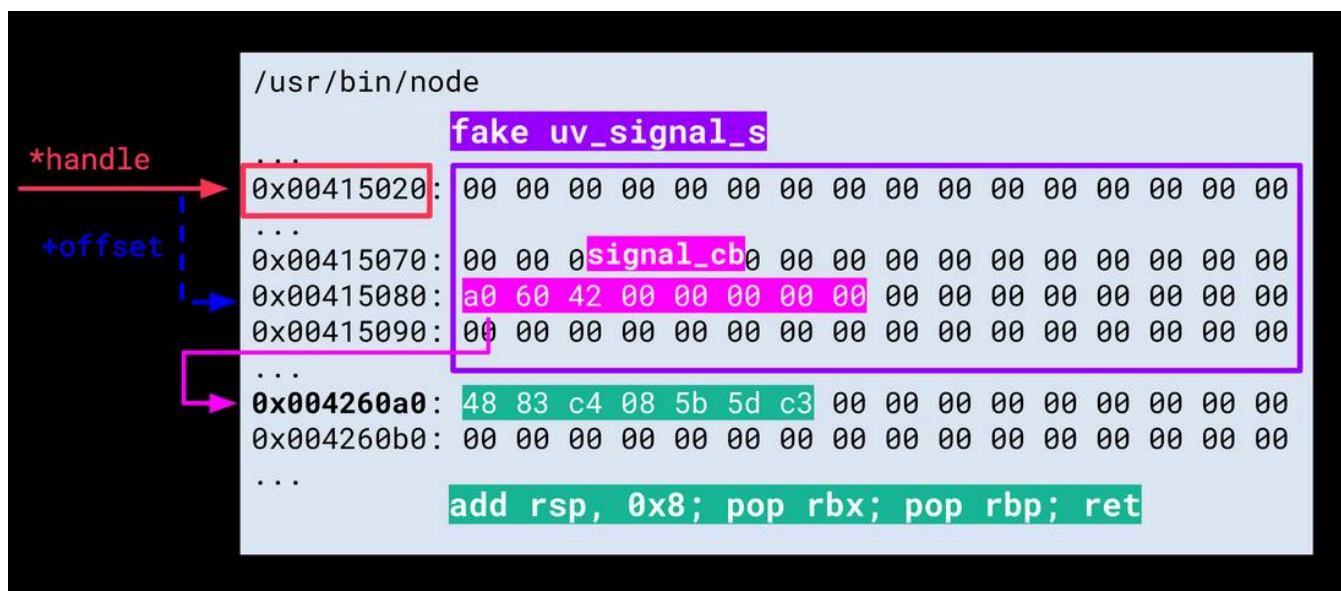
```
/usr/bin/node:      file format elf64-x86-64
```

Sections:				
Idx	Name	Size	VMA	LMA
12	.text	0182b2e4	0000000000b6b000	0000000000b6b000
CONTENTS, ALLOC, LOAD, READONLY, CODE				
...				
14	.rodata	02adfa18	0000000002396300	0000000002396300
...				
24	.got	000010b0	000000000529ef48	000000000529ef48
CONTENTS, ALLOC, LOAD, DATA				
25	.data	0003c9b8	00000000052a0000	00000000052a0000
CONTENTS, ALLOC, LOAD, DATA				
26	.bss	0002af08	00000000052dc9c0	00000000052dc9c0
...				
ALLOC				

Now the tool iterates over the bytes in this section and looks for a `ret` instruction, for example, since this is a suitable last instruction for a ROP gadget. The tool then goes from the byte that represents the `ret` instruction back again – byte by byte – to determine all possibly useful ROP gadgets:

```
/usr/bin/node
...
.text
0x00000000: 04 4a 23 25 24 23 00 82 08 99 10 00 88 24 10 3d
0x00000010: 00 00 48 05 40 01 00 00 5b 5d c3 41 c0 24 49 11
0x00000020: 7a 14 1c e1 00 81 c2 08 08 08 1c 80 02 07 82 44
0x00000030: 1c 90 38 18 68 95 04 00 11 96 e8 17 1a 42 8c 82
...
```

In this case, however, this is not what attackers need. Instead of a ROP gadget, they need an address that references a fake `uv_signal_s` data structure, which references a ROP gadget via its `signal_cb` function pointer. So, there is one indirection: the ROP gadget (address of a sequence of instructions) needs to be stored in the referenced data itself:



In order to identify suitable data structures like this, attackers need to search through the Node.js image similar to a classical ROP gadget finder tool. The difference, though, is that attackers are not only interested in executable sections like the `.text` section. The memory where the fake data structure resides does not have to be executable. Attackers need a pointer to a gadget. Thus, they can consider all segments that are at least readable. Also, this search can be done in-memory instead of only parsing the ELF file on disk. This way, attackers can also find data structures that were only created during runtime in the `.bss` section, for example. This may lead to false positives or environment-specific structures but increases their chance of getting useful findings, which can be verified manually.

A basic implementation of this in-memory search for fake data structures is actually pretty straightforward:

Copy to clipboard

```
for addr, len in nodejs_segments:
    for offset in range(len - 7):
        ptr = read_mem(addr + offset, 8)
        if is_mapped(ptr) and is_executable(ptr):
            instr = read_mem(ptr, n)
            if is_useful_gadget(instr):
                print('gadget at %08x' % addr + offset)
                print('-> ' + disassemble(instr))
```

The Python script iterates over all Node.js memory regions and interprets 8 bytes at a time as a pointer, which it tries to reference. If the address is mapped and references memory in an executable segment, it determines if the byte sequence stored at this address is a useful ROP gadget:

```
/usr/bin/node
```

```
...
```

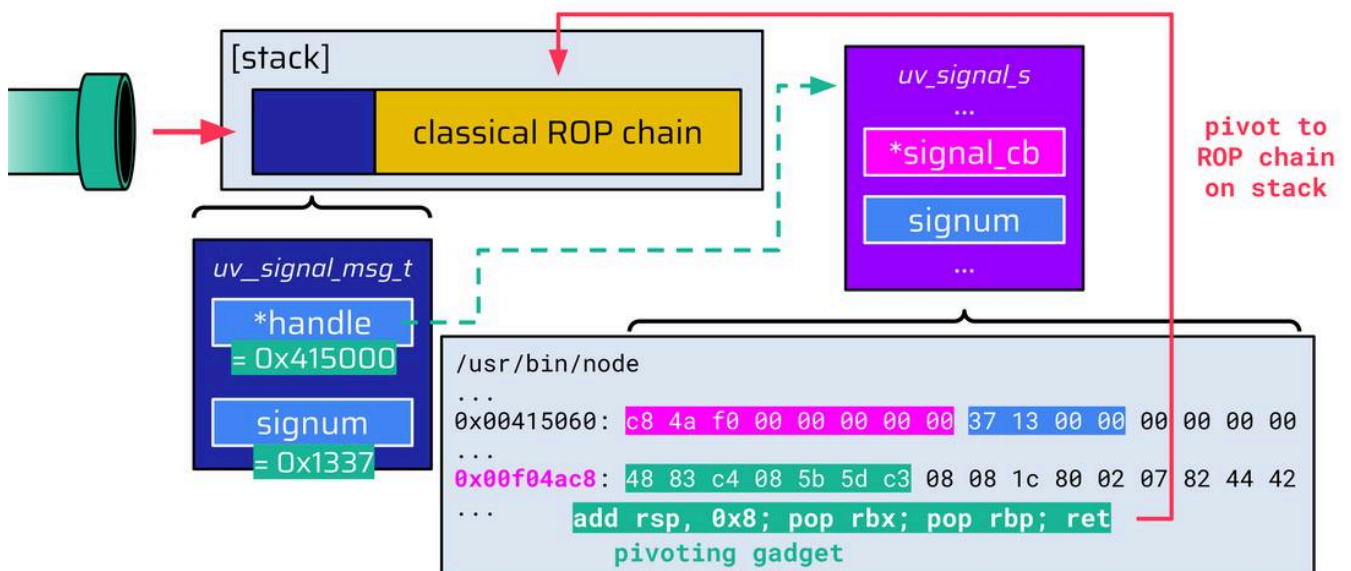
```
0x00400060: 00 00 e4 f9 8b 08 44 12 d3 eb 00 00 00 00 2c 2c  
0x00400070: 00 00 1a 3d 43 00 00 00 00 00 42 43 11 cf 2d 43  
0x00400080: ef fe 2e 00 00 00 00 00 ef d0 fc 00 00 00 00 00  
0x00400090: e2 a6 e6 da e5 54 29 2f f7 41 5f 16 72 31 41 bd  
0x004000a0: fe 5b d1 c6 77 25 7c 9a ef 52 e9 e7 30 42 63 dc  
0x004000b0: 00 00 00 00 00 00 00 00 0c 5c 88 9d 44 7d 48 57
```

This is what the Python script looks like in action:

A terminal window with a title bar that reads "user@h0st: ~/tools". The prompt is "user@h0st:~/tools\$". The command "sudo ./find_data_structures.py" has been entered and is followed by a cursor. The rest of the terminal is empty.

```
user@h0st:~/tools$ sudo ./find_data_structures.py
```

All potentially useful ROP gadgets are outputted and can now be used as the first initial ROP gadget that is executed when the callback function is invoked. Since all data written to the pipe is stored on the stack, it is sufficient to find a suitable pivoting gadget for this first gadget. Once attackers have pivoted the stack pointer to controlled data, a classical ROP chain can be used:



One caveat remains when using this technique to exploit an arbitrary file vulnerability. Usually, the function used to write the file (`fs.writeFile` in this case) is limited to valid UTF-8 data. Accordingly all data written to the pipe must be valid UTF-8.

Overcoming UTF-8 Restrictions

It is not challenging to find useful UTF-8-compatible gadgets for the classical ROP chain due to the huge size of the Node.js binary (~110M for the latest x64 build). However, this limitation further restricts the potentially suitable data structures for the fake `uv_signal_s` in the existing data. Based on this, an additional check needs to be added to the script to verify that the base address of the fake data structure is valid UTF-8:

Copy to clipboard

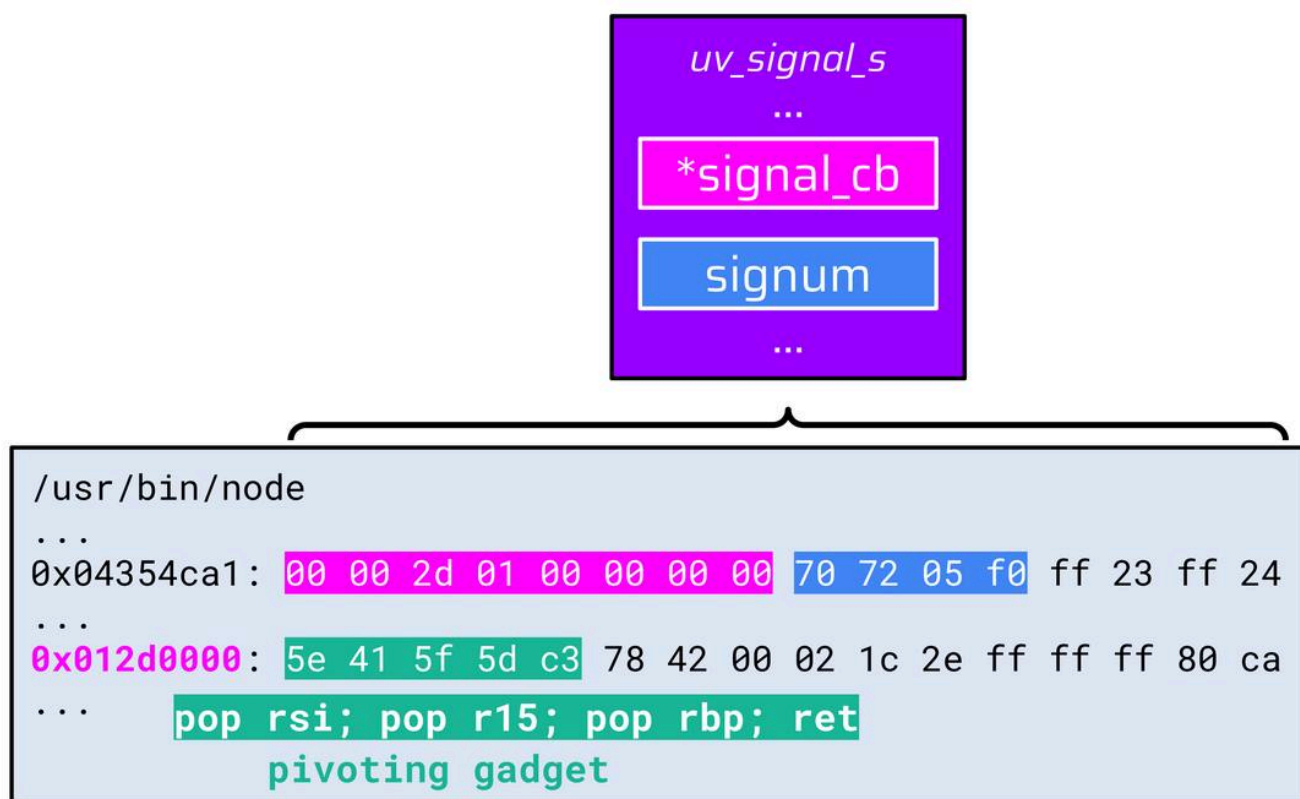
```
for addr, len in nodejs_segments:
    for offset in range(len - 7):
        {% mark yellow %}if not is_valid_utf8(addr + offset - 0x60): continue{% mark %}
        ptr = read_mem(addr + offset, 8)
        # [...]
```

Even with this additional check, the script still yields suitable fake data structures that reference a pivoting gadget like the following:

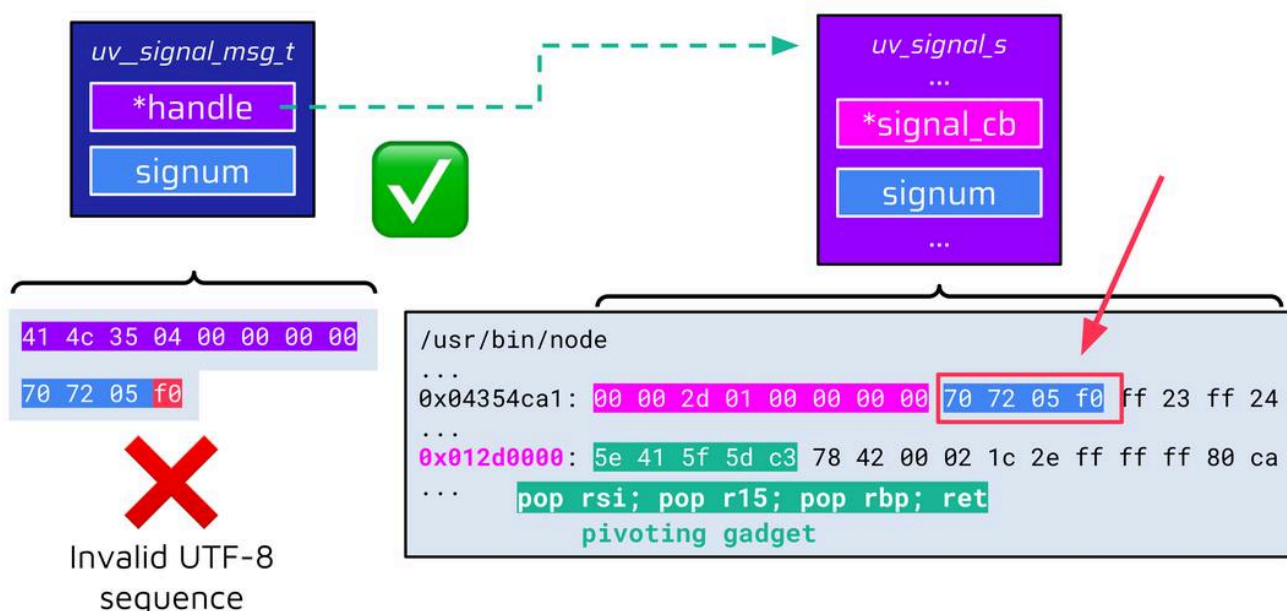
Copy to clipboard

```
...
0x4354ca1 -> 0x12d0000: pop rsi; pop r15; pop rbp; ret
...
```

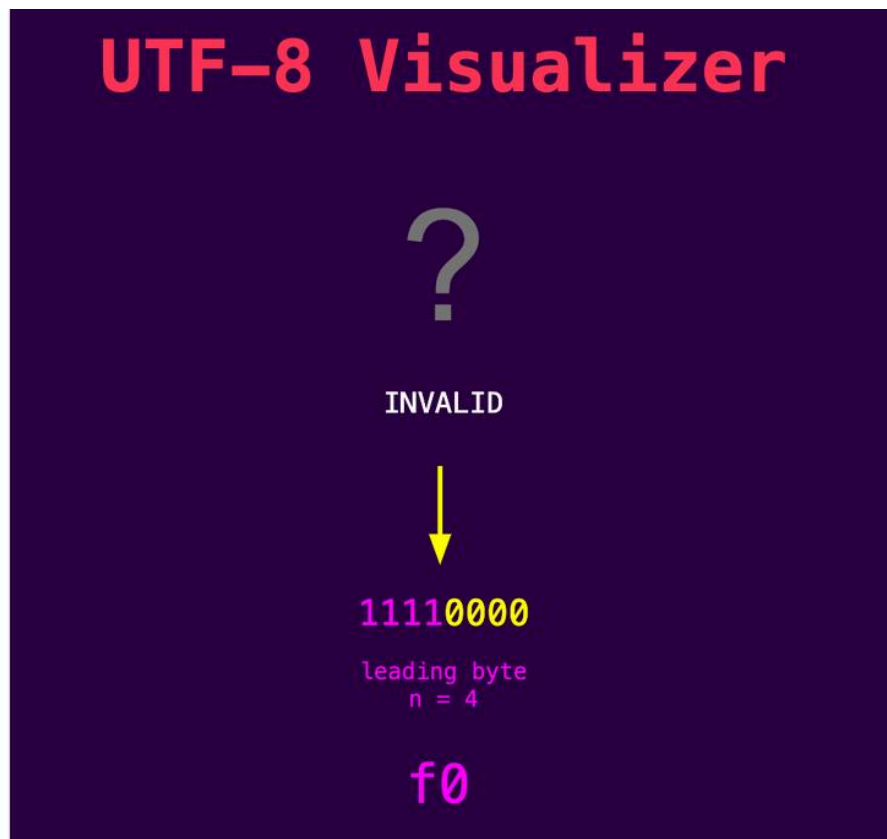
This is how the related data structure looks like in memory:



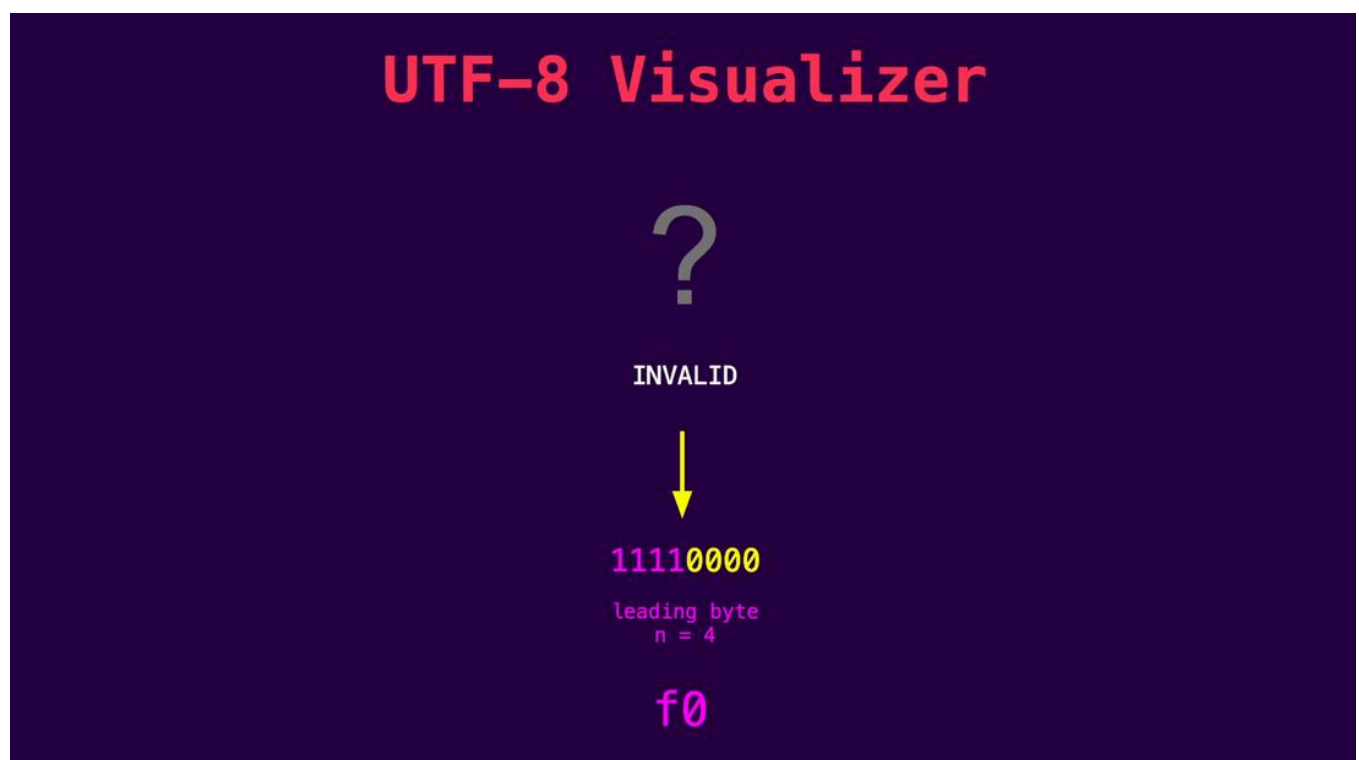
The base address of this fake data structure (`0x4354c41`) is valid UTF-8, so the `handle` pointer in the `uv_signal_msg_t` data structure can be correctly populated. However, there is another UTF-8-related problem. This time with the `signum` value:



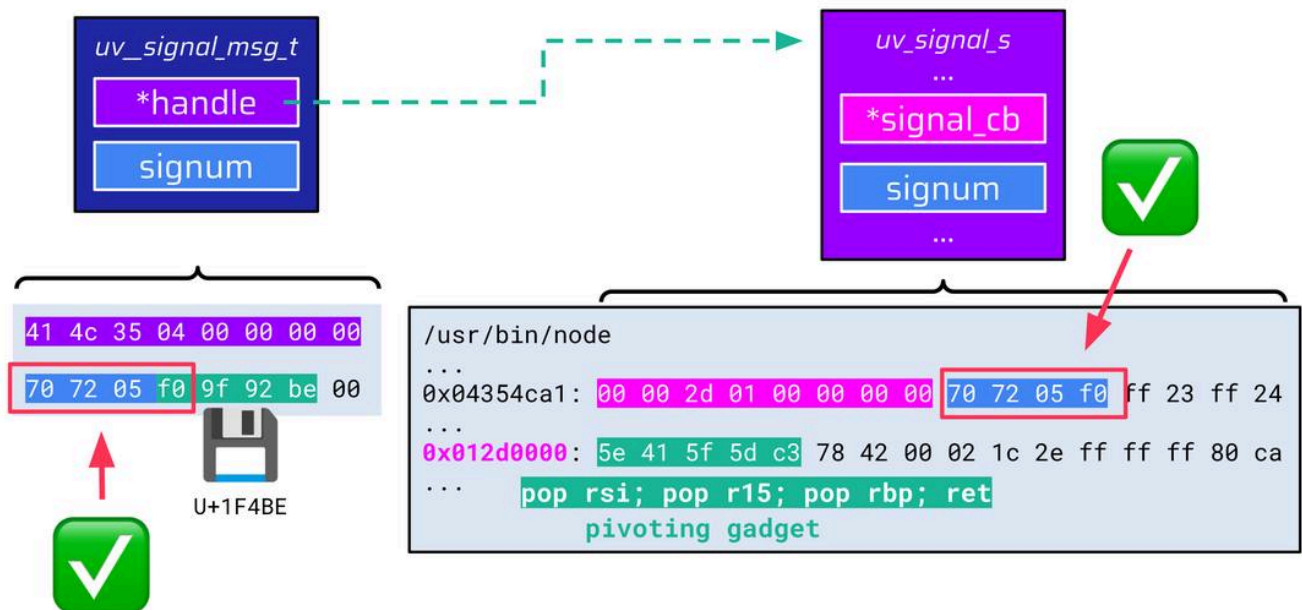
The last byte of the `signum` value is `0xf0`, which is not valid UTF-8. If an attacker tries to write this byte via the File Write vulnerability, it is replaced with a replacement character and the `signum` value check fails. If we enter `0xf0` in our [UTF-8 visualizer](#), we can see that this byte introduces a 4-byte UTF-8 sequence:



Accordingly, a UTF-8 parser expects 3 continuation bytes following this byte. Since the `uv_signal_msg_t` data structure contains an 8-byte pointer and a 4-byte integer, the compiler adds 4 additional padding bytes to align the structure to 16 bytes. These bytes can be used to add 3 continuation bytes and thus craft a valid UTF-8 sequence:



The above floppy disc, for example, is a valid 4-byte UTF-8 sequence that begins with `0xf0`. By adding these continuation bytes, attackers can fulfill the requirements of the whole payload being valid UTF-8 and make both `signum` values match:



With this last hurdle out of the way, attackers are able to gain remote code execution.

The following video demonstrates the exploit against the vulnerable example application, which is running as a **low-privileged user** on a system with a **read-only root file system** and **read-only procs**:

Learnings and Conclusion

The “*Everything is a file*” philosophy on Unix-based systems opens up uncommon attack surfaces when exploiting File Write vulnerabilities. In this blog post, we showcased this with a technique that can be used to turn a File Write vulnerability in a Node.js application into Remote Code Execution. Since the event handler code is from [libuv](#), this technique can also be applied to other software that uses libuv, like [julia](#).

The generic approach is even applicable without Node.js and libuv. Whenever an application uses pipes as a communication mechanism, attackers may leverage a File Write vulnerability to target the pipe file descriptors exposed via `procs`. As this example has shown, this might not be considered in a common threat model but can give remote attackers the ability to execute arbitrary code.

From a defensive perspective, this example highlights that infrastructure hardening can only be seen as an additional defense layer and cannot replace fundamental code security. Determined attackers can exploit vulnerabilities in the source code even though hardening measures have been employed. This greatly demonstrates why code security, as implied by [Code Quality](#), is so important and why vulnerabilities should be fixed at their origin: the source code.

- [Pretalx Vulnerabilities: How to get accepted at every conference](#)
- [Parallel Code Security: The Challenge of Concurrency](#)
- [Patches, Collisions, and Root Shells: A Pwn2Own Adventure](#)

[image: Icon]

Get new blogs delivered directly to your inbox!

Stay up-to-date with the latest Sonar content. Subscribe now to receive the latest blog articles.

Email

Choosing to proceed means that you agree to the storing and processing of your personal data as described in SonarSource's [Cookie Policy](#). You can opt out of SonarSource communications at anytime.

Sonar respects your privacy. Choosing to proceed means that you agree to the SonarSource's [Privacy Policy](#).

Archived from <https://www.sonarsource.com/blog/why-code-security-matters-even-in-hardened-environments/>.
Rendered offline from the local Markdown copy.